PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Journalisation Windows et Active Directory

03-510 ANSSI - Journalisation des systèmes Microsoft Windows en environnement Active Directory — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La journalisation doit être complétée par des analyses de risque, des travaux d'architecture et des audits de sécurité.
2. L'utilisation de Sysmon nécessite une phase de test préalable car il est fourni sans support logiciel officiel.
3. L'envoi d'événements d'un client WEF vers plusieurs serveurs WEC génère une redondance impactant le stockage centralisé.

Cadre et prérequis de la journalisation

Notion	À retenir
Objectif et périmètre	Décline les concepts de l'**ANSSI** pour **Windows**. Couvre la **journalisation locale** et la **centralisation** (enclave de collecte interne), hors systèmes sans connectivité régulière.
Synchronisation horloges	Plusieurs **sources internes cohérentes**, elles-mêmes sur des **sources externes fiables** (sauf réseau isolé). En **AD**, conserver la synchro par défaut sur les **contrôleurs de domaine** ; source de temps de la forêt sur les **NTP de référence**. Prérequis de **Kerberos**.

Journalisation locale Windows

Notion	À retenir
Journaux et tiers	Identifier/activer les journaux utiles. Privilégier les applications tierces utilisant des **journaux Windows structurés** plutôt que le journal `Application` ou un format propriétaire.
Stockage et audit	Configurer une **rotation automatique par effacement**. Modifier les **stratégies d'audit avancées** (insuffisantes par défaut) pour équilibrer volumétrie et pertinence selon l'analyse de risque.
Sysmon	Déployer en **service Windows automatique** sur entités à risque accru. Utiliser un fichier **XML** de règles. Risque de stabilité si **> 2000 lignes** de configuration.

Collecte des journaux d'événements

Notion	À retenir
Services natifs	Utilisation de **WEC** (Windows Event Collector) sur les serveurs de collecte et **WEF** (Windows Event Forwarding) sur les clients via des **abonnements**. **Plusieurs serveurs** : haute disponibilité, répartition de charge, chaînage, durées de conservation différenciées.
Sécurisation et sélection	Centraliser en **format brut**, surveiller le **stockage**, sécuriser le transfert et privilégier le mode **Push** plutôt que le mode **Pull**.
Cloisonnement et tiers	Serveurs de collecte dans une **architecture dédiée**. Proscrire les solutions tierces sur les **ressources sensibles de l'annuaire** ou les protéger spécifiquement.

Pièges et confusions

- ⚠ Considérer la journalisation comme la seule mesure de protection d'un système d'information
- ⚠ Déployer Sysmon rapidement et de manière généralisée sur des systèmes critiques sans test
- ⚠ Déployer une toute nouvelle version majeure de Sysmon en production avant une mise à jour mineure de correction
- ⚠ Oublier d'anticiper le dimensionnement du stockage lors de la configuration d'un client WEF vers plusieurs serveurs WEC

Sigles et définitions

Sysmon	Utilitaire de la suite Sysinternals offrant une journalisation avancée et configurable via un fichier XML
WECSvc	Service Windows Event Collector qui centralise les événements sur des serveurs de collecte
WEF	Windows Event Forwarding permettant aux systèmes clients de transférer leurs événements
Abonnement	Configuration sur un serveur collecteur précisant la sélection d'événements, les journaux et les ordinateurs concernés
Mode Push	Configuration où les clients WEF initient l'envoi de leurs événements vers le serveur de collecte
Enclave de collecte	Zone du SI regroupant les dispositifs de centralisation des événements

Auto-test

1. En environnement AD, sur quoi les systèmes se synchronisent-ils par défaut (configuration à conserver) ?
2. Quel est le risque de stabilité pour Sysmon lié à sa configuration ?
3. Comment doit être configurée la rotation des journaux ?
4. Quel mode de transfert est à privilégier pour la collecte ?
5. Que doit-on privilégier pour les applications tierces ?

Réponses : **1.** Sur les contrôleurs de domaine · **2.** Plus de 2000 lignes de configuration · **3.** Par effacement automatique · **4.** Le mode Push · **5.** Les journaux Windows structurés

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.